Informe técnico

Enumeración de TECNORIBERA, S.L.

Preparación del entorno y reconocimiento pasivo

Autor	Carlos Del Cerro
Fecha	29 de octubre de 2026
Módulo	Hacking ético - Red team básico (HE-E10)
Tipo de trabajo	Individual, laboratorio autorizado (empresa ficticia)
Dominio de laboratorio	tecnoribera.local
IP autorizada	172.20.10.4 (indicada por el profesor el 29/10; la anterior era 169.254.120.106)
Estado	Fase pasiva completada. Fase activa pendiente de conectividad con el laboratorio.

1. Alcance

El trabajo consiste en identificar los servicios de un laboratorio autorizado, interpretar los resultados y presentarlos en un informe técnico. Se trabaja solo contra el dominio de laboratorio **tecnoribera.local** y contra la IP que facilita el profesor. Queda fuera de alcance cualquier otro equipo, Internet o la infraestructura real del instituto, y no se explota ninguna vulnerabilidad, no se prueban credenciales ni se investiga a personas de la empresa.

El laboratorio Docker de TECNORIBERA lo ejecuta el profesor. La IP del portal cambió durante la practica (de 169.254.120.106 a 172.20.10.4) y el cambio se anotó en la bitácora.

2. Metodología

Se sigue la guía paso a paso de enumeración activa de TECNORIBERA, en este orden:

Fase	Qué se hace	Herramientas	Estado
0. Preparación	Comprobar que el equipo tiene el material listo	nmap, subfinder, httpx, ffuf, nuclei, whatweb	Hecha (con una incidencia, ver 3.1)
1. Carpeta y bitácora	Ordenar evidencias y registrar cada comando	mkdir, cat, echo	Hecha
2. Reconocimiento pasivo	Buscar información publica sin tocar al objetivo	crt.sh, subfinder, theHarvester, whois, dig	Hecha (sin datos, ver 4)
3-10. Enumeración activa	Mapear puertos, versiones, web, rutas y SMB	nmap, httpx, whatweb, wafw00f, ffuf, nuclei, enum4linux-ng	Pendiente (ver 6)
11-12. Ruido e inventario	Comparar con el SOC y consolidar hallazgos	Wazuh (compañeros de IC)	Pendiente

Cada hallazgo se separará en **confirmado** (visto con mis propios ojos, por ejemplo con curl) o **hipótesis** (indicio que aún no se ha comprobado). Una versión anunciada por un servicio no demuestra por sí sola que se pueda explotar una vulnerabilidad.

3. Preparación del entorno

3.1 Comprobación de herramientas

Antes de empezar se comprueba que las herramientas están instaladas pidiendo la versión de cada una. Si una no responde, no se puede usar luego y es mejor descubrirlo ahora que en mitad del escaneo.



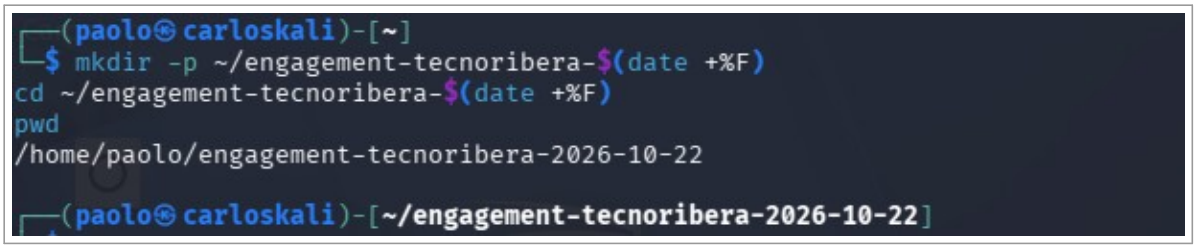
Captura 1. Versiones de las herramientas en la máquina virtual Kali Linux.

Herramienta	Resultado de la captura	Valoración
nmap	Nmap 7.991	Correcta
subfinder	Current Versión: v2.16.0	Correcta
httpx	Usage: httpx [OPTIONS] URL	**Incidencia:** es la librería Python, no la herramienta de ProjectDiscovery
ffuf	ffuf versión: 2.1.0-dev	Correcta
nuclei	Nuclei Engine Versión: v3.11.1	Correcta
whatweb	WhatWeb versión 0.6.4	Correcta

Incidencia con httpx. En Kali existen dos programas llamados httpx. El que aparece en la captura muestra un mensaje de uso (*Usage: httpx [OPTIONS] URL*) en lugar de un número de versión, lo que indica que es el cliente Python y no sirve para el trabajo de red team. La solución es instalar y usar **httpx-toolkit** en su lugar, y escribir siempre ese nombre cuando la guía diga httpx. Queda pendiente verificarlo cuando se llegue a la fase web.

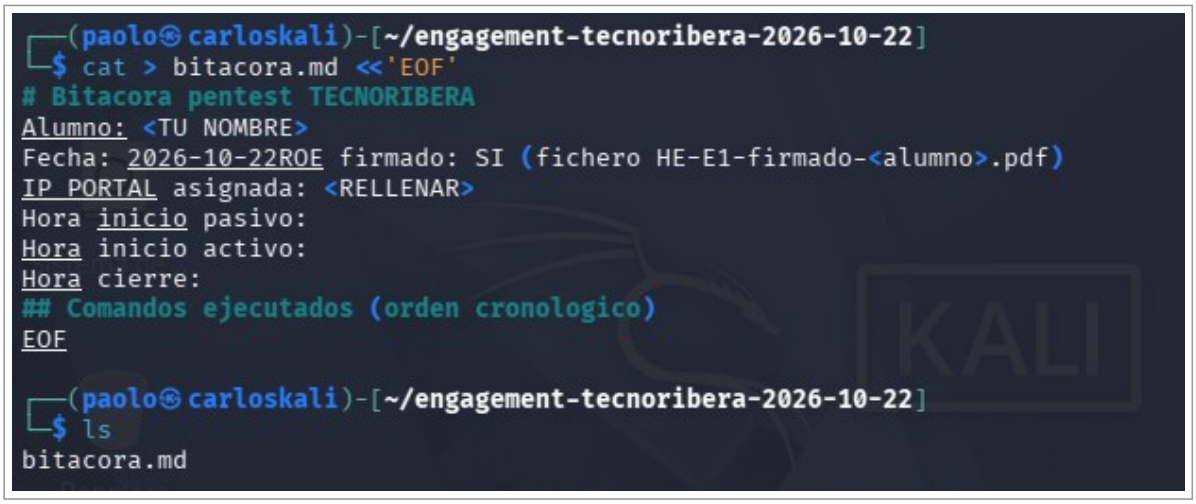
3.2 Carpeta de trabajo y bitácora

Se crea una carpeta con la fecha en el nombre para que todas las evidencias queden en un solo sitio. La fecha 2026-10-22 corresponde al día en que se creó, en la sesión anterior, y se ha seguido usando hoy.



Captura 2. Creación de la carpeta de trabajo y comprobación de la ruta con pwd.

Dentro se crea la bitácora, un fichero donde se anota cada comando y la hora. En un trabajo real, lo que no está documentado no existe.



Captura 3. Creación de bitacora.md con un heredoc (cat) y comprobación con ls. En esta primera versión los datos aún están sin rellenar; despues se completaron con el nombre, la fecha de hoy y la IP del profesor, y se añadieron los resultados del pasivo.

4. Reconocimiento pasivo

Esta fase consulta fuentes públicas y **no envía ningún paquete** al servidor de TECNORIBERA, de modo que el SOC no puede ver nada. Como el dominio es ficticio, lo esperable es no encontrar datos. Pero un resultado vacío solo es un "cero" fiable si se comprueba antes que la herramienta funciona, repitiendo la misma consulta contra un dominio real conocido (aquí, cipfpcheste.com).

4.1 Certificados públicos (crt.sh)

crt.sh es el registro público de certificados: si una empresa pidió un certificado para un subdominio, aparece ahí. Se lanzó primero la comprobación con el dominio real de control.

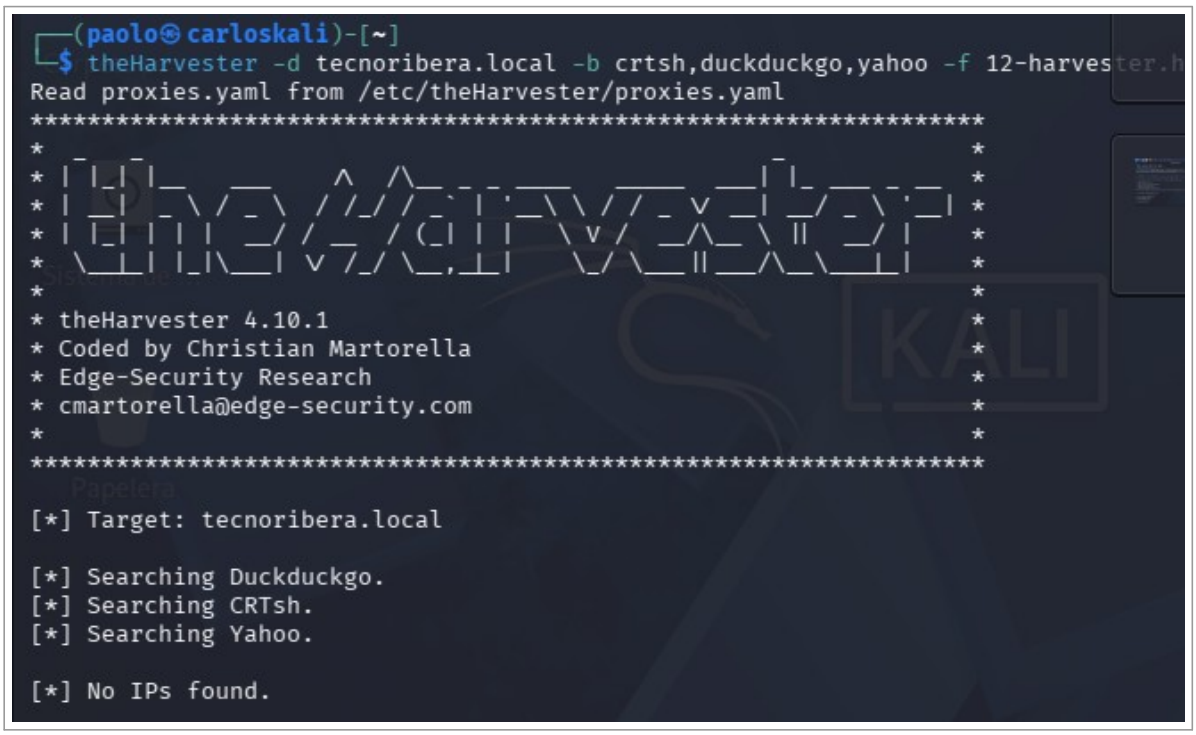


Captura 5. Consulta de control a crt.sh con cipfpcheste.com (el dominio real que sirve para verificar que la herramienta funciona).

La consulta de control no devolvió datos. Al pedir la respuesta sin filtrar, crt.sh contestó con un **502 Bad Gateway** de su servidor y, en otro intento, con un 404. El fallo es del servicio (saturado en ese momento), no del equipo: la conexión a Internet funciona, ya que desde el navegador se accede sin problema. Por tanto, el resultado vacío para tecnoribera.local **no se considera un cero verificado**.

4.2 Subdominios y correos (subfinder y theHarvester)

subfinder consulta muchas fuentes públicas a la vez, y theHarvester busca correos y nombres de equipos citados en buscadores. En theHarvester la fuente *bing* ya no es válida en la versión instalada (4.10.1) y hubo que quitarla para que el programa arrancase.



Captura 4. theHarvester 4.10.1 contra tecnoribera.local con las fuentes crtsh, duckduckgo y yahoo. La herramienta se ejecuta correctamente; la captura muestra el aviso de que no encontró IPs.

El resumen completo de theHarvester fue: 0 IPs, 0 correos, 0 personas y 0 hosts. subfinder tampoco devolvió nada, ni siquiera con el dominio de control, así que tampoco es un cero verificado. Es razonable pensar que influye que crt.sh estaba caído, porque subfinder lo usa como una de sus fuentes, aunque esto es una hipótesis que no se ha comprobado.

4.3 Whois y DNS

whois pregunta quién registró un dominio, y dig consulta los registros DNS: NS (quien manda en el dominio), MX (correo) y TXT (donde viven SPF y DMARC, los filtros contra la suplantacion de correo).

Consulta	Resultado	Interpretación
whois tecnoribera.local	"No se conoce ningún servidor de whois para esta clase de objeto"	Esperable: .local no es un dominio de Internet
dig NS	Sin respuesta	El dominio no existe en el DNS consultado
dig MX	Sin respuesta	Ídem
dig TXT	Sin respuesta	Sin datos: **no se puede concluir** que falten SPF o DMARC

Resumen de la fase pasiva:

Fuente	Resultado para tecnoribera.local	Control con dominio real	Valor del resultado
crt.sh	Sin datos	Fallo (404/502)	No verificado
subfinder	Sin datos	Sin datos	No verificado
theHarvester	0 IPs, 0 correos, 0 hosts	No realizado	No verificado
whois / dig	Sin datos	No aplica (dominio .local)	Coherente con un dominio ficticio

5. Hallazgos

5.1 Confirmados

No hay hallazgos de seguridad confirmados en la fase pasiva. Lo único confirmado son dos incidencias de entorno:

#	Hallazgo	Cómo se confirmó
1	crt.sh devuelve 404/502 y no puede usarse ahora mismo	Respuesta en bruto con curl en la terminal (502 Bad Gateway)
2	El comando httpx de la máquina no es el de ProjectDiscovery	Captura 1: muestra Usage en lugar de una versión

5.2 Hipótesis (sin comprobar)

#	Hipótesis	Qué hace falta para comprobarla
1	subfinder devuelve vacío porque crt.sh está caído	Repetir subfinder con dominio de control cuando crt.sh vuelva a responder
2	Un dominio .local no tiene SPF ni DMARC públicos porque no existe en Internet	No es comprobable ni relevante en un dominio de laboratorio

5.3 Enumeración activa

Pendiente. Aún no se han lanzado escaneos contra 172.20.10.4. La tabla de activos queda preparada para rellenarse con la información de nmap -sV:

Host	Puerto	Servicio	Versión observada	Método de comprobación	Estado
172.20.10.4	-	-	-	nmap -sV, curl -I	Pendiente

Para cada hallazgo se anotará qué se quería descubrir, el comando usado y la conclusión que permiten los datos, separando lo confirmado de lo hipotetico.

6. Limitaciones

Limitación	Efecto	Cómo se documentó
Sin conectividad con la IP del laboratorio. curl a 172.20.10.4 da timeout y el ping a la primera IP (169.254.120.106) no recibe respuesta. El profesor está trabajando en solucionarlo.	No se pueden hacer los bloques activos (nmap, web, ffuf, nuclei, SMB)	Anotado en la bitácora con la hora
crt.sh caído (404/502), también con dominio de control	El cero de certificados no está verificado	Anotado en la bitácora y en este informe
subfinder y theHarvester sin datos; en subfinder el control con dominio real tampoco devolvió nada	Los ceros no están verificados	Anotado en la bitácora y en este informe
El ping puede estar bloqueado en la red del centro	Un 100% de pérdida no prueba por sí solo que no haya red	Se usan curl y nmap -Pn como alternativa
Dominio ficticio .local	whois y DNS no tienen nada que devolver	Conclusión marcada como "sin datos"

7. Recomendaciones

Para este trabajo concreto, una mitigación por cada incidencia detectada:

Incidencia	Recomendación
httpx incorrecto	Instalar httpx-toolkit (sudo apt install -y httpx-toolkit) y usar siempre ese nombre.
crt.sh no responde	Reintentar más tarde y, mientras tanto, apoyarse en otras fuentes. Apuntar siempre la hora y el error.
Ceros sin verificar	Repetir cada consulta vacía contra un dominio real antes de escribir "no hay nada" en un informe.
Sin acceso a la IP	Confirmar con el profesor la IP vigente y comprobar que la máquina virtual está en modo adaptador puente.

Las recomendaciones de seguridad para TECNORIBERA (una mitigación concreta por hallazgo) se añadirán cuando se complete la enumeración activa.

8. Próximos pasos

Cuando el profesor restablezca el acceso a la IP del laboratorio, el orden de trabajo es:

Paso	Qué se hace	Evidencia
1	Comprobar conexión con curl -I a 172.20.10.4 y guardar la IP en la bitácora	Salida de curl
2	nmap rápido de los 1000 puertos más comunes y anotar el tiempo	21-nmap-rapido.*
3	nmap lento y sigiloso (-T2 -f) y comparar tiempos	22-nmap-lento.*
4	nmap -sV -sC sobre los puertos abiertos para ver servicios y versiones	23-nmap-versiones.*
5	Fingerprint web (httpx-toolkit, whatweb, wafw00f)	30, 31 y 32
6	ffuf para rutas ocultas y verificación de cada una con curl	40-ffuf-rutas.json
7	nuclei (severidad baja y alta) y verificación manual de los críticos	50 y 51
8	enum4linux-ng si el puerto 445 está abierto	60-smb.yaml
9	Medir el ruido con los compañeros de IC (Wazuh) y consolidar el inventario HE-E10	70-medicion-ruido.md

Al terminar se detienen los contenedores vulnerables y no se comparten credenciales.